

MODELO DE ENCUESTA INTEGRAL FISMA 2025

Diagnóstico de Madurez en Ciberseguridad Institucional

Basada en los Indicadores FY2025 IG FISMA Reporting Metrics v2.0, NIST CSF 2.0, ENS (RD 311/2022) y Directiva NIS2

Nota al encuestado: Esta encuesta es un viaje, no un examen. No hay respuestas incorrectas; sólo hay organizaciones que ya saben dónde están y organizaciones que están a punto de descubrirlo. Su honestidad es el activo más valioso de este proceso. El tiempo estimado de cumplimentación es de **45-60 minutos** para la versión completa o **20-25 minutos** para la versión abreviada (módulos I, II y IX).

DATOS DE IDENTIFICACIÓN DEL RESPONDENTE

Campo	Respuesta
Organización (nombre o código anonimizado)	
Comunidad Autónoma / Sector	
Tipo de entidad	☐ AAPP Autonómica ☐ AAPP Local ☐ AGE ☐ Empresa privada sectorial ☐ Infraestructura crítica ☐ Otro
Rol del respondente	☐ CISO / Responsable de Seguridad ☐ CIO / Director TI ☐ Director General ☐ Responsable de Cumplimiento ☐ DPO ☐ Otro
Antigüedad en el cargo	☐ < 1 año ☐ 1-3 años ☐ 3-5 años ☐ > 5 años
Plantilla total de la organización	☐ < 50 ☐ 50-250 ☐ 251-1.000 ☐ 1.001-5.000 ☐ > 5.000
¿Dispone la organización de un CISO o equivalente formal?	☐ Sí, con dedicación exclusiva ☐ Sí, con dedicación parcial ☐ No, la función recae en el CIO ☐ No existe la función
Fecha de cumplimentación	

MÓDULO I — GOBERNANZA DE LA CIBERSEGURIDAD

(Función GOVERN del NIST CSF 2.0 · Dominio 1 FISMA FY2025 · Art. 13 RD 311/2022)

"Una organización que no puede explicar su postura de seguridad a su junta directiva tiene, de hecho, dos problemas: el de seguridad y el de gobernanza. Y ambos son igual de urgentes."

P1. ¿Existe en su organización una Política de Seguridad de la Información formalmente aprobada por el máximo órgano directivo (Consejo, Junta de Gobierno, Dirección General)?

- ☐ A) Sí, aprobada formalmente, revisada en los últimos 12 meses y comunicada a toda la organización
- ☐ B) Sí, aprobada formalmente, pero no revisada desde hace más de 2 años
- ☐ C) Existe un borrador o documento interno, pero sin aprobación formal del órgano directivo
- ☐ D) No existe política formal; la seguridad se gestiona de forma reactiva y basada en criterio técnico individual
- ☐ E) No lo sé con certeza — y eso ya es, en sí mismo, una respuesta reveladora

P2. ¿En qué medida participa el máximo órgano directivo de su organización en las decisiones estratégicas de ciberseguridad?

- ☐ A) Activamente: recibe informes trimestrales o más frecuentes sobre postura de riesgo, incidentes y evolución de métricas, y toma decisiones formales al respecto
- ☐ B) Moderadamente: se informa al órgano directivo en caso de incidente grave o auditoría, pero no hay ciclo regular
- ☐ C) Formalmente: la dirección aprueba documentos cuando se le presentan, pero no impulsa la agenda
- ☐ D) Marginalmente: la ciberseguridad se considera un asunto técnico que "resuelve el departamento de informática"
- ☐ E) Prácticamente nula: el órgano directivo conoce la existencia del problema, pero lo considera ajeno a sus funciones

P3. ¿Dispone su organización de una estrategia de gestión del riesgo cibernético documentada, con prioridades, tolerancias al riesgo y criterios de aceptación explícitos?

- ☐ A) Sí, documentada, aprobada y alineada con la estrategia corporativa o institucional global
- ☐ B) Sí, documentada, pero desconectada de la estrategia corporativa (vive en su propio silo)
- ☐ C) Parcialmente: existen algunos criterios de riesgo, pero sin coherencia sistémica ni aprobación formal
- ☐ D) No: el riesgo se gestiona implícitamente, basándose en la experiencia del equipo técnico
- ☐ E) El concepto de "tolerancia al riesgo" suena interesante, pero todavía no se ha aterrizado en ningún documento

P4. ¿Utiliza su organización los Perfiles del Marco NIST CSF 2.0 (o equivalente ENS) para articular, priorizar y comunicar objetivos de ciberseguridad?

- ☐ A) Sí, disponemos de un Perfil Actual y un Perfil Objetivo documentados y actualizados
- ☐ B) Sí, utilizamos el CSF 2.0 / ENS como referencia, pero sin perfiles formales
- ☐ C) Conocemos el marco pero aún no lo hemos implementado formalmente
- ☐ D) Trabajamos con otro marco (ISO 27001, CIS Controls, COBIT...); especificar: _____
- ☐ E) No utilizamos ningún marco de referencia estructurado

P5. ¿Existe un proceso formal de rendición de cuentas y evaluación del desempeño en ciberseguridad que incluya objetivos medibles para los responsables?

- ☐ A) Sí: existen KPIs de ciberseguridad integrados en los objetivos de rendimiento de directivos y responsables TI
- ☐ B) Sí, pero sólo para el CISO o el equipo de seguridad, no para la dirección general
- ☐ C) Existen indicadores, pero no están vinculados a evaluaciones formales de desempeño
- ☐ D) No existen KPIs formales de ciberseguridad
- ☐ E) La ciberseguridad se evalúa sólo cuando hay incidentes; si no hay incidentes (que sepamos), se asume que todo va bien

MÓDULO II — GESTIÓN DE RIESGOS EN LA CADENA DE SUMINISTRO (C-SCRM)

(Función GOVERN · Dominio 2 FISMA FY2025 · Art. 19 RD 311/2022 · NIS2 Art. 21)

"La cadena de suministro es el nuevo perímetro. Y tiene el diámetro de todos sus proveedores juntos."

P6. ¿Dispone su organización de un inventario actualizado de proveedores y terceros con acceso (lógico o físico) a sus sistemas de información o datos?

- ☐ A) Sí, inventario completo con clasificación por nivel de criticidad y riesgo potencial, actualizado al menos trimestralmente
- ☐ B) Sí, inventario existente pero con cobertura parcial (algunos proveedores no están incluidos o no está actualizado)
- ☐ C) Lista informal mantenida por el equipo TI, sin criterios de criticidad
- ☐ D) No existe inventario formal de proveedores desde una perspectiva de seguridad
- ☐ E) No sabemos cuántos proveedores tienen acceso a nuestros sistemas — lo cual, reconocemos, no es la respuesta más tranquilizadora

P7. ¿Incluye su organización cláusulas de ciberseguridad en los contratos con proveedores tecnológicos y prestadores de servicios digitales?

- ☐ A) Sí, de forma sistemática: todos los contratos TIC incluyen requisitos de seguridad, derechos de auditoría y obligación de notificación de incidentes
- ☐ B) Sí, en contratos de mayor valor o criticidad, pero no de forma universal
- ☐ C) Se incluyen cláusulas genéricas de confidencialidad, pero sin requisitos específicos de ciberseguridad
- ☐ D) No se incluyen requisitos de ciberseguridad en los contratos de forma estándar
- ☐ E) El proceso de contratación no pasa por el equipo de seguridad

P8. ¿Realiza su organización evaluaciones de ciberseguridad de proveedores antes de la contratación o renovación?

- ☐ A) Sí: cuestionarios de seguridad estandarizados, análisis de certificaciones (ISO 27001, ENS, SOC2) y/o pruebas técnicas antes de la adjudicación
- ☐ B) Se solicitan certificaciones o declaraciones de conformidad, pero sin verificación activa
- ☐ C) Se hacen verificaciones informales para proveedores críticos, sin proceso estandarizado
- ☐ D) No se realizan evaluaciones de ciberseguridad durante la selección de proveedores
- ☐ E) El criterio dominante en la selección de proveedores es el precio; la seguridad es una pregunta que no suele hacerse

P9. ¿Se realiza un seguimiento continuo del estado de seguridad de los proveedores tras la contratación?

- ☐ A) Sí: monitorización continua o revisiones periódicas formales (al menos anuales) con criterios objetivos
- ☐ B) Revisiones puntuales ante incidentes o renovaciones contractuales
- ☐ C) Se confía en la autocertificación del proveedor sin verificación adicional
- ☐ D) No existe seguimiento post-contratación desde la perspectiva de ciberseguridad

P10. ¿Dispone su organización de un plan de contingencia para interrupciones críticas provocadas por fallos o compromisos de seguridad en proveedores clave?

- ☐ A) Sí, plan documentado, probado y con proveedores alternativos identificados
- ☐ B) Plan documentado pero no probado en ejercicios reales
- ☐ C) Existe una identificación de dependencias críticas, pero sin plan de contingencia formal
- ☐ D) No existe plan de contingencia específico para fallos de proveedores

MÓDULO III — GESTIÓN DE RIESGOS Y ACTIVOS

(Función IDENTIFY · Dominio 3 FISMA FY2025 · Medida op.exp.1 ENS)

"No puedes proteger lo que no sabes que tienes. Y si no sabes lo que tienes, probablemente tampoco sabes lo que ya has perdido."

P11. ¿Dispone su organización de un inventario completo y actualizado de activos de información (hardware, software, datos y servicios)?

- ☐ A) Sí, inventario automático y continuo mediante herramientas CMDB/ITAM, actualizado en tiempo real o casi real
- ☐ B) Sí, inventario manual actualizado periódicamente (al menos trimestralmente)
- ☐ C) Inventario parcial: cubre los sistemas críticos pero no los secundarios, dispositivos personales o IoT
- ☐ D) Inventario obsoleto o incompleto; se actualiza sólo tras incidentes o auditorías
- ☐ E) No existe inventario formal; cada departamento gestiona sus propios activos de forma independiente

P12. ¿Están todos los sistemas de información categorizados o clasificados por nivel de criticidad e impacto en caso de compromiso?

- ☐ A) Sí, categorización completa siguiendo ENS (Básica/Media/Alta) o equivalente, documentada y revisada
- ☐ B) Sí, con categorización informal o basada en criterios propios no alineados con ENS/NIST
- ☐ C) Sólo los sistemas más críticos están categorizados; el resto no
- ☐ D) No existe categorización formal de sistemas

P13. ¿Se realizan análisis de riesgos formales sobre los sistemas de información de forma periódica?

- ☐ A) Sí, análisis de riesgos completos y documentados (con herramientas como PILAR, MAGERIT, OCTAVE o equivalente) al menos anualmente y tras cambios significativos
- ☐ B) Sí, análisis periódicos pero con metodología informal o parcialmente documentada
- ☐ C) Se realizan análisis puntuales para proyectos o ante auditorías, pero no como ciclo regular
- ☐ D) No se realizan análisis de riesgos formales

P14. ¿Existe un proceso para la gestión de activos IoT y sistemas de Tecnología Operacional (OT) integrado en la gestión general de activos de seguridad?

- ☐ A) Sí, los activos IoT/OT están inventariados, categorizados y monitorizados con las mismas políticas que los activos TI convencionales
- ☐ B) Los activos IoT/OT están identificados, pero gestionados de forma separada y con menor nivel de control
- ☐ C) Conocemos la existencia de activos IoT/OT pero no están formalmente integrados en la gestión de seguridad
- ☐ D) Los activos IoT/OT no están en el radar del equipo de seguridad
- ☐ E) No disponemos de activos IoT/OT (o, al menos, eso creemos)

MÓDULO IV — GESTIÓN DE LA CONFIGURACIÓN

(Función PROTECT · Dominio 4 FISMA FY2025 · Medidas técnicas ENS)

"Una configuración insegura por defecto es como dejar la llave bajo el felpudo: todo el mundo sabe dónde buscarla, excepto, aparentemente, el propietario."

P15. ¿Dispone su organización de líneas base de configuración segura (hardening) para todos los tipos de sistemas (servidores, estaciones de trabajo, dispositivos móviles, equipos de red)?

- ☐ A) Sí, líneas base documentadas, automatizadas y verificadas continuamente mediante herramientas (SCAP, CIS Benchmarks, STIG equivalentes)
- ☐ B) Sí, líneas base documentadas y aplicadas, pero verificación manual y periódica
- ☐ C) Líneas base parciales: existen para los sistemas más críticos pero no para todos los tipos
- ☐ D) No existen líneas base formales; la configuración depende del criterio del técnico responsable

P16. ¿Cuál es el tiempo medio de aplicación de parches críticos de seguridad en su organización?

- ☐ A) < 24 horas para parches críticos (CVSS $\geq$ 9.0); < 72 horas para parches altos
- ☐ B) Entre 1 y 7 días para parches críticos
- ☐ C) Entre 1 semana y 1 mes
- ☐ D) > 1 mes; el ciclo de parcheo es irregular o reactivo
- ☐ E) No tenemos métricas de tiempo de parcheo — lo cual es, en sí mismo, una vulnerabilidad de gestión

P17. ¿Se utiliza algún sistema de gestión automatizada de vulnerabilidades con escaneos periódicos y trazabilidad de remediación?

- ☐ A) Sí, herramienta automatizada con escaneos semanales o más frecuentes, integrada con el sistema de tickets y con métricas de SLA de remediación
- ☐ B) Sí, herramienta automatizada pero con escaneos mensuales o menos frecuentes
- ☐ C) Escaneos manuales o servicios externos puntuales (pentest anual, auditorías)
- ☐ D) No se realizan escaneos de vulnerabilidades de forma sistemática

P18. ¿Existe un proceso formal de gestión de cambios en sistemas de información que incluya evaluación de impacto en seguridad antes de la implementación?

- ☐ A) Sí, proceso formal con CAB (Change Advisory Board) que incluye valoración de seguridad obligatoria para todos los cambios
- ☐ B) Sí, proceso de gestión de cambios, pero la valoración de seguridad es opcional o sólo para cambios mayores
- ☐ C) Proceso informal; los cambios se documentan a posteriori o sólo para sistemas críticos
- ☐ D) No existe proceso formal de gestión de cambios

MÓDULO V — GESTIÓN DE IDENTIDADES Y ACCESOS (IDAM / Zero Trust)

(Función PROTECT · Dominio 5 FISMA FY2025 · Métricas suplementarias ZTA · ENS control de acceso)

"En un mundo Zero Trust, confiar es el problema, no la solución. La identidad es el nuevo perímetro, y el MFA es su primera línea de defensa. Todo lo demás es nostalgia del cortafuegos."

P19. ¿Está implementada la autenticación multifactor (MFA) en su organización?

- ☐ A) Sí, MFA obligatorio para todos los usuarios en todos los accesos a sistemas (incluyendo aplicaciones web, VPN, correo, administración de sistemas)
- ☐ B) MFA implementado para accesos privilegiados (administradores, CISO, dirección) y sistemas críticos
- ☐ C) MFA implementado parcialmente: sólo para acceso remoto o aplicaciones específicas
- ☐ D) MFA disponible pero de uso voluntario; no es obligatorio
- ☐ E) No está implementado el MFA; se utiliza sólo usuario y contraseña

P20. ¿Se realiza una revisión periódica de los permisos y accesos de todos los usuarios, incluyendo cuentas privilegiadas, de servicio y de terceros?

- ☐ A) Revisión formal al menos trimestral con proceso documentado, trazabilidad y certificación de accesos
- ☐ B) Revisión anual o semestral
- ☐ C) Revisión puntual: cuando hay cambios organizativos o auditorías
- ☐ D) No se realizan revisiones periódicas de accesos
- ☐ E) No existe un inventario completo de cuentas de usuario activas — con todo lo que eso implica

P21. ¿Está implementado el principio de mínimo privilegio de forma sistemática en la asignación de permisos de acceso?

- ☐ A) Sí, de forma rigurosa: los usuarios sólo tienen los accesos estrictamente necesarios para sus funciones, revisados y documentados
- ☐ B) Sí, en principio, pero en la práctica existen excepciones frecuentes no documentadas
- ☐ C) Aplicado para cuentas privilegiadas, pero no para usuarios estándar
- ☐ D) No se aplica de forma sistemática: prevalece la conveniencia operativa sobre el principio de mínimo privilegio

P22. ¿Dispone su organización de capacidades de gestión de accesos privilegiados (PAM)?

- ☐ A) Sí, solución PAM implementada con bóveda de credenciales, acceso just-in-time y registro completo de sesiones privilegiadas
- ☐ B) Sí, solución PAM parcial: bóveda de credenciales sin gestión completa de sesiones
- ☐ C) Controles manuales: cuentas privilegiadas documentadas y con contraseñas gestionadas, pero sin herramienta PAM
- ☐ D) No existe gestión específica de accesos privilegiados; las cuentas de administrador se usan de forma directa y sin control adicional

P23. ¿Está su organización implementando o evaluando una Arquitectura Zero Trust (ZTA)?

- ☐ A) Sí, estrategia ZTA formalmente aprobada con hoja de ruta, métricas de progreso y pilares en implementación activa (Identidad, Dispositivos, Redes, Aplicaciones, Datos)
- ☐ B) En evaluación: existe una iniciativa ZTA en fase de diseño o piloto
- ☐ C) Se conoce el concepto y existe voluntad, pero no hay proyecto formal aún
- ☐ D) No es una prioridad actual
- ☐ E) Zero Trust es un término que escuchamos en conferencias; aún no ha cruzado la puerta de nuestra organización

MÓDULO VI — PROTECCIÓN DE DATOS Y PRIVACIDAD

(Función PROTECT · Dominio 6 FISMA FY2025 · LOPDGDD · ENS cifrado)

"Los datos son el nuevo petróleo, dicen. Pero a diferencia del petróleo, cuando se derraman, no te manchan las manos: manchan las reputaciones, los balances y, a veces, los juzgados."

P24. ¿Dispone su organización de un inventario o mapa de datos (data map) que identifique dónde se almacenan, procesan y transmiten los datos de carácter personal y los datos críticos de negocio?

- ☐ A) Sí, mapa de datos completo, actualizado y con clasificación por nivel de sensibilidad
- ☐ B) Sí, mapa de datos existente pero parcial o no actualizado regularmente
- ☐ C) Existe el Registro de Actividades de Tratamiento (RAT) del RGPD, pero sin mapeo técnico de flujos de datos
- ☐ D) No existe mapa de datos formal

P25. ¿Está implementado el cifrado de datos en reposo y en tránsito para los datos clasificados como sensibles o críticos?

- ☐ A) Sí, cifrado implementado de forma sistemática para datos en reposo (AES-256 o equivalente) y en tránsito (TLS 1.2+ obligatorio), con gestión formal de claves criptográficas
- ☐ B) Cifrado implementado para datos en tránsito pero parcial para datos en reposo
- ☐ C) Cifrado implementado para sistemas específicos críticos, pero no de forma universal
- ☐ D) El cifrado se aplica sólo donde la plataforma lo incluye por defecto, sin política explícita
- ☐ E) El cifrado no es una práctica sistemática en nuestra organización

P26. ¿Realiza su organización evaluaciones de impacto en privacidad (DPIA/EIPD) para nuevos tratamientos de datos de alto riesgo?

- ☐ A) Sí, de forma sistemática: proceso formal con criterios claros de activación, documentación y supervisión del DPO
- ☐ B) Sí, cuando el equipo jurídico o el DPO lo identifica como necesario, pero sin proceso sistemático
- ☐ C) Se han realizado DPIAs puntuales para proyectos específicos
- ☐ D) No se realizan DPIAs de forma regular

P27. ¿Está su organización evaluando o preparándose para la transición a criptografía post-cuántica (PQC)?

- ☐ A) Sí, existe un inventario de sistemas criptográficos vulnerables a ataques cuánticos y una hoja de ruta de migración hacia los estándares NIST PQC (FIPS 203/204/205)
- ☐ B) En fase de evaluación: conocemos el riesgo y estamos analizando el impacto en nuestra infraestructura
- ☐ C) Lo hemos identificado como amenaza futura pero sin acciones concretas aún
- ☐ D) La computación cuántica nos parece, por el momento, suficientemente lejana como para no preocuparnos

MÓDULO VII — FORMACIÓN Y CONCIENCIACIÓN EN SEGURIDAD

(Función PROTECT · Dominio 7 FISMA FY2025 · Art. 15-16 RD 311/2022)

"El factor humano sigue siendo el vector de ataque favorito de los adversarios. No porque los humanos seamos malos; es porque somos eficientemente explotables cuando no estamos formados."

P28. ¿Dispone su organización de un programa formal de formación y concienciación en ciberseguridad para todo el personal?

- ☐ A) Sí, programa anual obligatorio para todo el personal, con módulos diferenciados por rol, métricas de completitud y evaluación de efectividad
- ☐ B) Sí, formación anual obligatoria pero uniforme (sin diferenciación por rol)
- ☐ C) Formación disponible pero voluntaria; no existe obligatoriedad ni seguimiento
- ☐ D) Formación puntual reactiva: sólo tras incidentes o cuando lo requiere una auditoría
- ☐ E) No existe programa de formación en ciberseguridad

P29. ¿Realiza su organización simulacros de phishing u otras pruebas de ingeniería social para evaluar la preparación del personal?

- ☐ A) Sí, simulacros periódicos (al menos trimestrales) con análisis de resultados, formación remedial para el personal que falla y métricas de mejora a lo largo del tiempo
- ☐ B) Sí, simulacros anuales, pero sin seguimiento sistemático de mejora
- ☐ C) Se han realizado simulacros puntuales, pero no como práctica regular
- ☐ D) No se realizan simulacros de phishing
- ☐ E) Confiamos en la percepción general de que "nuestro personal no pica en ese tipo de cosas" — lo cual es, estadísticamente, una afirmación optimista

P30. ¿Reciben los directivos y el Consejo de Dirección formación específica en ciberseguridad orientada a sus responsabilidades de gobernanza y toma de decisiones?

- ☐ A) Sí, formación específica para directivos al menos anualmente, adaptada a su perfil y responsabilidades
- ☐ B) Los directivos participan en la misma formación general que el resto del personal
- ☐ C) Se realizan sesiones informativas puntuales (briefings) para directivos, sin estructura formativa
- ☐ D) Los directivos no participan en programas de formación en ciberseguridad

MÓDULO VIII — MONITORIZACIÓN CONTINUA DE LA SEGURIDAD (ISCM)

(Función DETECT · Dominio 8 FISMA FY2025 · Art. 24 RD 311/2022 · CDM Program)

"Una organización que sólo detecta los ataques que ya ha sufrido no tiene un sistema de detección: tiene un sistema de documentación del daño."

P31. ¿Dispone su organización de un SIEM (Security Information and Event Management) o sistema equivalente de correlación de eventos de seguridad?

- ☐ A) Sí, SIEM implementado con reglas de correlación actualizadas, cobertura del 90%+ de los activos críticos, alertas con triaje automatizado y equipo de análisis dedicado
- ☐ B) Sí, SIEM implementado pero con cobertura parcial o sin recursos de análisis dedicados
- ☐ C) Herramientas de logging básicas, pero sin correlación centralizada ni analítica
- ☐ D) No existe monitorización centralizada de eventos de seguridad

P32. ¿Dispone su organización de capacidades de detección y respuesta en endpoints (EDR/XDR)?

- ☐ A) Sí, EDR/XDR implementado en el 90%+ de endpoints (estaciones de trabajo, servidores, dispositivos móviles corporativos)
- ☐ B) EDR implementado en servidores y sistemas críticos, pero no en todos los endpoints
- ☐ C) Antivirus convencional en todos los endpoints; EDR sólo en sistemas seleccionados
- ☐ D) Sólo antivirus convencional; no disponemos de capacidades EDR/XDR

P33. ¿Cuál es la cobertura de los registros (logs) de eventos de seguridad en su organización?

- ☐ A) Logs centralizados del 90%+ de sistemas, con retención mínima de 12 meses y conforme a los niveles EL1-EL3 del OMB M-21-31 o equivalente
- ☐ B) Logs centralizados del 50-90% de sistemas; retención entre 6-12 meses
- ☐ C) Logs disponibles en cada sistema pero sin centralización ni análisis sistemático
- ☐ D) Logging mínimo o sin política formal de registro de eventos

P34. ¿Ha implementado su organización el programa CDM (Continuous Diagnostics and Mitigation) o un sistema equivalente de diagnóstico continuo?

(Pregunta orientada a entidades del sector público o proveedores de infraestructura crítica)

- ☐ A) Sí, implementado con al menos el 90% de activos GFE cubiertos y datos enviados a autoridad supervisora (CCN-CERT/INCIBE/CISA equivalente)
- ☐ B) Implementado parcialmente; cobertura inferior al 90% de activos
- ☐ C) En proceso de implementación
- ☐ D) No implementado / No aplica a nuestra organización

P35. ¿Realiza su organización ejercicios de threat hunting (caza proactiva de amenazas) de forma periódica?

- ☐ A) Sí, threat hunting proactivo realizado por equipo interno o MSSP al menos trimestralmente, con hipótesis documentadas y resultados formalizados
- ☐ B) Esporádicamente, generalmente tras alertas de inteligencia de amenazas (CTI)
- ☐ C) No se realiza threat hunting; la detección es reactiva (basada en alertas)
- ☐ D) No disponemos de capacidades de threat hunting ni acceso a servicios que las proporcionen

MÓDULO IX — RESPUESTA A INCIDENTES

(Función RESPOND · Dominio 9 FISMA FY2025 · Art. 25 RD 311/2022 · NIS2 notificación 24/72h)

"Un plan de respuesta a incidentes que no se ha probado no es un plan: es una lista de buenos propósitos redactada bajo la ilusión de que los incidentes avisarán antes de llegar."

P36. ¿Dispone su organización de un Plan de Respuesta a Incidentes (IRP) documentado, aprobado y actualizado?

- ☐ A) Sí, IRP completo con roles, responsabilidades, playbooks por tipo de incidente, canales de comunicación y criterios de escalada, revisado en los últimos 12 meses
- ☐ B) Sí, IRP documentado pero no actualizado en los últimos 2 años o sin playbooks específicos
- ☐ C) Procedimientos informales o parciales; no hay un IRP completo como documento único
- ☐ D) No existe un Plan de Respuesta a Incidentes formal

P37. ¿Se realizan ejercicios y simulacros de respuesta a incidentes (tabletop exercises, simulaciones, red team/blue team) de forma periódica?

- ☐ A) Sí, ejercicios al menos anuales con participación de la dirección, resultados documentados y mejoras incorporadas al IRP
- ☐ B) Sí, ejercicios realizados pero sólo con el equipo técnico, sin participación directiva
- ☐ C) Se han realizado ejercicios puntuales; no existe cadencia regular
- ☐ D) No se realizan ejercicios de respuesta a incidentes

P38. ¿Cuáles son los tiempos de respuesta objetivo (SLA) de su organización para incidentes de seguridad?

(Puede seleccionar múltiples opciones que describan su situación)

- ☐ A) Definidos y medidos: tiempo de detección, contención, erradicación y recuperación con objetivos documentados y monitorizados
- ☐ B) Definidos para incidentes críticos; no para incidentes de menor severidad
- ☐ C) No existen SLA formales de respuesta a incidentes
- ☐ D) Los tiempos de respuesta se miden sólo a posteriori, sin objetivos previos

P39. ¿Cumple su organización con los requisitos de notificación de incidentes a las autoridades competentes (CCN-CERT, INCIBE-CERT, AEPD, CNPIC) en los plazos establecidos?

- ☐ A) Sí, con proceso formal: criterios de notificación documentados, plantillas preparadas y notificaciones realizadas en plazo (< 24h alerta / < 72h notificación completa según NIS2)
- ☐ B) Sí, pero sin proceso formal: las notificaciones se realizan pero de forma ad hoc
- ☐ C) Se han notificado incidentes en el pasado, pero no siempre en plazo o con la información requerida
- ☐ D) No tenemos claro cuándo es obligatorio notificar ni a qué autoridad
- ☐ E) No hemos tenido incidentes que requirieran notificación (o eso creemos)

P40. ¿Dispone su organización de un equipo de respuesta a incidentes (CSIRT/CERT) interno o de un servicio MSSP con capacidades de IR?

- ☐ A) CSIRT interno con personal dedicado, disponibilidad 24/7 y procedimientos formalizados
- ☐ B) Capacidades de IR distribuidas en el equipo TI/Seguridad, sin CSIRT formal pero con procedimientos
- ☐ C) Contrato con MSSP que incluye IR; sin capacidades internas dedicadas
- ☐ D) No disponemos de capacidades de IR internas ni de contrato MSSP para este fin

MÓDULO X — CONTINUIDAD DE NEGOCIO Y RECUPERACIÓN

(Función RECOVER · Dominio 10 FISMA FY2025 · Art. 26 RD 311/2022)

"La diferencia entre una organización que sobrevive a un incidente mayor y una que no, raramente se encuentra en el momento del ataque. Se encuentra en los ejercicios de continuidad que nadie quiso hacer el año anterior."

P41. ¿Dispone su organización de un Plan de Continuidad de Negocio (BCP) y/o Plan de Recuperación ante Desastres (DRP) formalmente documentados?

- ☐ A) Sí, BCP y DRP completos, coordinados entre sí, aprobados por la dirección y revisados en los últimos 12 meses
- ☐ B) Sí, existen documentos, pero no están coordinados o están desactualizados (> 2 años)
- ☐ C) Existe un DRP técnico para los sistemas más críticos, sin BCP organizativo completo
- ☐ D) No existen BCP ni DRP formales

P42. ¿Se han probado los planes de continuidad y recuperación mediante ejercicios o pruebas reales en el último año?

- ☐ A) Sí, pruebas completas (full failover test) al menos anuales con resultados documentados y mejoras implementadas
- ☐ B) Sí, pruebas parciales (tabletop exercises, pruebas de backup/restore) sin failover completo
- ☐ C) Se probaron hace más de 2 años; desde entonces no se han realizado pruebas
- ☐ D) Los planes no han sido probados; existen sobre el papel pero no en la práctica

P43. ¿Cuáles son los objetivos de recuperación (RTO y RPO) de su organización para los sistemas críticos?

- ☐ A) Definidos, documentados y probados: RTO y RPO por sistema/servicio crítico, con resultados de pruebas que confirman su alcanzabilidad
- ☐ B) Definidos y documentados, pero no probados de forma rigurosa
- ☐ C) Establecidos informalmente, sin documentación formal
- ☐ D) No existen objetivos RTO/RPO definidos; la recuperación se gestionará "cuando ocurra"

P44. ¿Existe una estrategia de backup robusta para los datos y sistemas críticos que cumpla la regla 3-2-1 o equivalente?

- ☐ A) Sí: al menos 3 copias en 2 medios diferentes, con 1 copia offsite/offline; backups probados regularmente y con cifrado
- ☐ B) Backups regulares en múltiples ubicaciones, pero sin cumplir todos los criterios 3-2-1
- ☐ C) Backups regulares en una única ubicación o sin copia offsite
- ☐ D) Backups irregulares o sin política formal de backup

MÓDULO XI — CUMPLIMIENTO NORMATIVO Y AUDITORÍA

(Transversal · ENS Art. 31-36 · NIS2 · LOPDGDD · FISMA IG Audits)

"El cumplimiento normativo sin seguridad real es teatro. La seguridad real sin cumplimiento normativo es, paradójicamente, también arriesgada. La combinación de ambos, en cambio, es lo que los auditores llaman 'una buena tarde'."

P45. ¿Tiene su organización la certificación ENS (Básica, Media o Alta) para sus sistemas de información?

- ☐ A) Sí, certificación vigente para todos los sistemas de la categoría correspondiente
- ☐ B) Certificación vigente para algunos sistemas; otros en proceso
- ☐ C) En proceso de certificación: adecuación iniciada, pero aún sin certificado formal
- ☐ D) Adecuación al ENS en curso sin certificación formal (usando µCeENS u otras herramientas CCN)
- ☐ E) No hemos iniciado el proceso de adecuación al ENS
- ☐ F) No aplica: nuestra organización no está en el ámbito de aplicación del ENS

P46. ¿Está su organización en el ámbito de aplicación de la Directiva NIS2 (entidad esencial o importante)?

- ☐ A) Sí, identificados como entidad esencial; cumplimiento en proceso activo de implementación
- ☐ B) Sí, identificados como entidad importante; cumplimiento en proceso
- ☐ C) Posiblemente en ámbito pero aún no hemos realizado la autoevaluación
- ☐ D) No estamos en el ámbito de aplicación de NIS2

Si respondió A, B o C: ¿Qué aspectos de NIS2 considera más complejos de implementar?

- ☐ Notificación de incidentes en 24/72 horas
- ☐ Gestión de riesgos en la cadena de suministro
- ☐ Responsabilidad ejecutiva y formación de directivos
- ☐ Registro y notificación ante la autoridad nacional competente
- ☐ Medidas técnicas (seguridad de redes, cifrado, control de accesos)
- ☐ Todos los anteriores; NIS2 es generosamente desafiante

P47. ¿Con qué frecuencia se realizan auditorías independientes de seguridad de la información en su organización?

- ☐ A) Auditorías anuales por tercero independiente acreditado, con informes formales y POA&M gestionado
- ☐ B) Auditorías bienales o cada 3 años
- ☐ C) Auditorías puntuales (ante certificaciones, incidentes o requerimientos externos)
- ☐ D) No se realizan auditorías independientes de seguridad

P48. ¿Dispone su organización de un Plan de Acción y Mejora (PAM/POA&M) para gestionar las deficiencias identificadas en auditorías, análisis de riesgos y evaluaciones de seguridad?

- ☐ A) Sí, PAM formalizado con propietarios, fechas de resolución, priorización por riesgo y seguimiento periódico de progreso
- ☐ B) Sí, PAM existente pero con seguimiento irregular
- ☐ C) Las deficiencias se registran, pero sin un proceso formal de seguimiento unificado
- ☐ D) Las deficiencias se tratan de forma reactiva cuando resurgen o cuando hay recursos disponibles

MÓDULO XII — MÉTRICAS, INDICADORES Y MADUREZ

(Transversal · FISMA Maturity Model 5 niveles · ENISA NIS Investments · ENS INES)

"Una organización que no mide su postura de seguridad confunde el silencio con la tranquilidad. Los adversarios, en cambio, llevan contando desde hace tiempo."

P49. ¿Utiliza su organización métricas e indicadores (KPIs/KRIs) de ciberseguridad de forma sistemática?

- ☐ A) Sí: panel de indicadores (dashboard) activo con métricas cuantitativas de rendimiento y riesgo, revisado al menos mensualmente y reportado a la dirección
- ☐ B) Sí, métricas definidas pero revisadas sólo periódicamente (trimestral o anual)
- ☐ C) Indicadores parciales: algunos datos disponibles pero sin estructura formal de KPI/KRI
- ☐ D) No utilizamos métricas formales de ciberseguridad; la evaluación es cualitativa e impresionista

P50. ¿En qué nivel de madurez situaría a su organización en el modelo de 5 niveles FISMA/NIST?

(Autoevaluación global)

- ☐ Nivel 1 — Ad Hoc: Sin formalización; respuesta reactiva; la seguridad depende de heroísmos individuales
- ☐ Nivel 2 — Defined: Políticas documentadas existentes, pero su implementación es tan consistente como el tiempo en el Cantábrico
- ☐ Nivel 3 — Consistently Implemented: Implementación uniforme y reproducible; sabemos qué hacemos, aunque no siempre podemos demostrarlo con datos
- ☐ Nivel 4 — Managed and Measurable: Métricas cuantitativas activas; gestionamos con datos reales; alcanzamos el umbral de efectividad según los estándares internacionales
- ☐ Nivel 5 — Optimized: Mejora continua institucionalizada; nuestra postura de seguridad evoluciona más rápido que las amenazas — y tenemos datos para demostrarlo

P51. ¿Cuál es el presupuesto dedicado a ciberseguridad como porcentaje del presupuesto total de TI?

- ☐ A) > 15% del presupuesto TI
- ☐ B) Entre el 10% y el 15%
- ☐ C) Entre el 5% y el 10%
- ☐ D) < 5% del presupuesto TI
- ☐ E) No existe un presupuesto de ciberseguridad diferenciado del presupuesto general de TI
- ☐ F) No tengo esta información disponible

(Referencia: la media europea de entidades NIS es 1,5M€ de presupuesto de seguridad; las organizaciones que aumentan su presupuesto de seguridad +10% anual reducen su superficie de riesgo un 40% en 3 años según ENISA NIS Investments 2025)

P52. ¿Ha sufrido su organización incidentes de seguridad significativos en los últimos 12 meses?

- ☐ A) Sí, uno o más incidentes críticos (afectación a servicios esenciales, fuga de datos, ransomware)
- ☐ B) Sí, incidentes moderados (infección de malware contenida, intentos de phishing exitosos)
- ☐ C) Incidentes menores gestionados sin impacto operativo significativo
- ☐ D) No hemos sufrido incidentes significativos

Si respondió A o B: ¿Cuál fue el principal vector de ataque?

- ☐ Phishing / Ingeniería social
- ☐ Ransomware
- ☐ Explotación de vulnerabilidades conocidas (sin parchear)
- ☐ Compromiso de credenciales
- ☐ Ataque a la cadena de suministro (proveedor comprometido)
- ☐ Amenaza interna (insider)
- ☐ Otro: _____

MÓDULO XIII — INTELIGENCIA DE AMENAZAS Y TENDENCIAS EMERGENTES

(Transversal · CCN-CERT CTI · ENISA Threat Landscape · IA y Computación Cuántica)

P53. ¿Utiliza su organización inteligencia de amenazas (CTI) de forma activa?

- ☐ A) Sí: suscripción a feeds CTI relevantes (MISP, ISAC sectorial, CCN-CERT), integración con SIEM y proceso de análisis y acción sobre inteligencia recibida
- ☐ B) Sí: suscripción a boletines y alertas (CCN-CERT, INCIBE-CERT), pero sin integración técnica automatizada
- ☐ C) Consumo pasivo de informes públicos de inteligencia de amenazas
- ☐ D) No utilizamos inteligencia de amenazas de forma estructurada

P54. ¿Cuál es el nivel de preparación de su organización frente a las amenazas emergentes de Inteligencia Artificial aplicada a ciberataques?

(Deepfakes, phishing generativo, evasión de EDR mediante IA adversarial)

- ☐ A) Alto: hemos actualizado nuestros controles, formación y procesos para tener en cuenta las capacidades de ataque asistidas por IA
- ☐ B) Medio: somos conscientes de la amenaza y estamos evaluando ajustes a nuestros controles
- ☐ C) Bajo: conocemos la amenaza pero no hemos tomado medidas específicas todavía
- ☐ D) Muy bajo: la IA como vector de ataque no ha entrado en nuestra agenda de seguridad aún

P55. ¿Participa su organización en grupos de intercambio de información sobre ciberseguridad (ISACs, foros sectoriales, grupos de trabajo CCN, redes CSIRT)?

- ☐ A) Sí, participación activa: contribuimos con información y recibimos inteligencia relevante de forma regular
- ☐ B) Sí, participación pasiva: recibimos información pero contribuimos escasamente
- ☐ C) Miembros nominales, con participación mínima o nula en la práctica
- ☐ D) No participamos en ningún grupo de intercambio de información

MÓDULO XIV — PREGUNTAS ABIERTAS Y REFLEXIÓN ESTRATÉGICA

"Las respuestas de opción múltiple capturan la estructura; las preguntas abiertas capturan la realidad. Ambas son necesarias para un diagnóstico honesto."

P56. (Pregunta abierta) ¿Cuál considera que es el mayor obstáculo para mejorar la postura de ciberseguridad de su organización?

(Espacio libre — máx. 300 palabras)

P57. (Pregunta abierta) Si pudiera implementar una sola mejora en el próximo trimestre, con impacto real y medible en su nivel de madurez de ciberseguridad, ¿cuál sería?

(Espacio libre — máx. 200 palabras)

P58. (Pregunta abierta) ¿Qué aspectos del marco FISMA FY2025, del ENS o de la Directiva NIS2 considera más aplicables o más urgentes para su contexto territorial (comunidad autónoma / sector)?

(Espacio libre — máx. 300 palabras)

P59. En una escala del 1 al 10, ¿cómo valoraría la cultura de ciberseguridad de su organización?

[1] – [2] – [3] – [4] – [5] – [6] – [7] – [8] – [9] – [10]

(1 = "La cultura de seguridad es, en el mejor de los casos, una aspiración"; 10 = "La ciberseguridad es parte del ADN organizativo, y tenemos datos que lo demuestran")

P60. ¿Recomendaría esta encuesta a otras organizaciones de su sector como herramienta de autodiagnóstico?

- ☐ A) Sí, con entusiasmo: es una herramienta valiosa y necesaria
- ☐ B) Sí, con reservas: es útil pero mejorable en algunos aspectos
- ☐ C) Neutral: cumpliría la función, aunque no la destacaría especialmente
- ☐ D) No: prefiero otras herramientas de diagnóstico que considera más adecuadas; especificar:

DECLARACIÓN DE CONSENTIMIENTO Y CONFIDENCIALIDAD

El respondente declara que las respuestas proporcionadas reflejan, con la mayor fidelidad posible, la situación real de su organización en la fecha de cumplimentación. Los datos serán tratados de acuerdo con el Reglamento General de Protección de Datos (RGPD) y la Ley Orgánica de Protección de Datos y Garantía de Derechos Digitales (LOPDGDD). Los resultados se emplearán exclusivamente con fines de investigación académica y mejora del sistema de métricas de ciberseguridad, garantizando el anonimato de las organizaciones participantes salvo autorización expresa.

Firma / Identificación del respondente: _____

Fecha: _____

Kit de Encuesta FISMA 2025 — Versión 1.0 · Abril 2026

*Basado en: OMB M-25-04, FY2025 IG FISMA Reporting Metrics v2.0, NIST CSF 2.0, RD 311/2022 (ENS),
Directiva NIS2, ENISA NIS Investments 2025*